

AI Evidence Pack Checklist

Template

Use this checklist to assemble a complete, reviewable, and audit-ready evidence package for an AI use case.

Use Case Name:	Use Case ID / Risk ID:
Business Owner:	AI Governance Owner:
Risk Tier: ☐ Low ☐ Moderate ☐ High ☐ Critical	
Environment: ☐ Pilot ☐ Production ☐ Retired	
Evidence Pack Version:	Prepared By:
Date Prepared:	Review Period Covered:

1) Evidence Pack Cover & Index

- ☐ Cover page with use case name, version, date, owners
- ☐ Evidence pack table of contents / index included
- ☐ Document control/version history included
- ☐ Links/locations to source evidence included (SharePoint, GRC tool, ticket system, etc.)
- ☐ Evidence pack completeness status documented (Complete / Partial / Pending)

Notes:

2) Use Case Authorization & Intake Evidence

- ☐ AI Use Case Intake Form (completed)
- ☐ Business justification / problem statement
- ☐ Scope definition (pilot / production / affected users)
- ☐ Triage outcome and risk tier assignment
- ☐ Approval record(s) for intake / launch decision
- ☐ Exception record(s), if any (with expiry date and compensating controls)

Evidence Link(s):

3) Governance & Policy Compliance Evidence

- ☐ AI Governance Policy applicability confirmation
- ☐ Applicable standards/procedures identified
- ☐ Control mapping (policy/standard → implemented controls)
- ☐ Compliance requirements identified (privacy, cyber, sector, contract, etc.)
- ☐ Policy exception or deviation approval (if applicable)
- ☐ Governance review meeting minutes / decision log (if used)

Evidence Link(s):

4) Risk Assessment & Triage Evidence

- ☐ AI risk assessment completed (scoring + rationale)
- ☐ Technology/security risk assessment completed
- ☐ Compliance risk register entry created/updated
- ☐ Residual risk rating documented
- ☐ Risk treatment plan documented (accept / mitigate / transfer / avoid)
- ☐ Risk owner and due dates assigned

Evidence Link(s):

5) Privacy & Data Protection Evidence

- ☐ Data classification documented (PII/PHI/PCI/etc.)
- ☐ Data flow documented (source → processing → storage → output)
- ☐ Lawful basis / privacy basis identified (if applicable)
- ☐ DPIA/PIA completed (if required)
- ☐ Cross-border data transfer assessment completed (if applicable)
- ☐ Data minimization and retention requirements documented
- ☐ Privacy notice / consent impact assessment completed (if applicable)
- ☐ DPA / privacy terms reviewed (for vendor AI)

Evidence Link(s):

6) Security Control Evidence

- ☐ Security architecture review completed

- ☐ Authentication / SSO / MFA controls documented
- ☐ Access controls and roles approved (least privilege)
- ☐ Logging and audit trail enabled
- ☐ Encryption in transit / at rest confirmed (if applicable)
- ☐ Secrets / API key management documented
- ☐ Vulnerability/security testing evidence (as applicable)
- ☐ Threat model completed (required for high/critical risk)
- ☐ Incident response contacts and escalation path documented
- ☐ DLP / prompt handling controls documented (if applicable)

Evidence Link(s):

7) Model / System Documentation Evidence

- ☐ Model/system description documented (type, purpose, limitations)
- ☐ Model source identified (internal / vendor / OSS / API)
- ☐ Model card or equivalent documentation (if applicable)
- ☐ Training data/source summary documented (if applicable)
- ☐ Version information captured (model version, vendor release, API version)
- ☐ Known limitations / prohibited uses documented
- ☐ Human oversight requirements documented

Evidence Link(s):

8) Vendor / Third-Party Evidence (if applicable)

- ☐ Vendor risk assessment completed
- ☐ Contract / MSA / DPA reviewed and approved
- ☐ Vendor security documentation collected (SOC 2 / ISO / etc.)
- ☐ Data retention/training usage terms confirmed
- ☐ Subprocessor list reviewed
- ☐ Incident notification commitments confirmed
- ☐ Hosting region / data residency confirmed
- ☐ SLA / service dependency documented

Evidence Link(s):

9) Testing, Validation & Quality Evidence

- ☐ Test plan approved before go-live
- ☐ Functional testing results documented
- ☐ Evaluation metrics defined and recorded (accuracy, precision, relevance, etc.)
- ☐ Failure mode testing / edge cases documented
- ☐ Hallucination/error handling evaluation (for GenAI)
- ☐ Bias/fairness assessment completed (if applicable)
- ☐ User acceptance testing (UAT) evidence included
- ☐ Go-live readiness decision documented

Evidence Link(s):

10) Monitoring & Operations Evidence

- ☐ Monitoring plan documented (what is monitored + thresholds)
- ☐ Logging/telemetry evidence available
- ☐ Drift/performance review schedule defined (if applicable)
- ☐ Incident/issue tracking process documented
- ☐ Periodic review cadence defined (annual / quarterly / etc.)
- ☐ Change management process for model/vendor updates documented
- ☐ Re-approval/reauthorization trigger criteria documented

Evidence Link(s):

11) Human Oversight & Accountability Evidence

- ☐ Human reviewer role(s) identified
- ☐ Escalation path for incorrect/harmful outputs documented
- ☐ Override/fallback process documented
- ☐ Training/awareness provided to users/reviewers
- ☐ Accountability matrix (business, IT, security, privacy, legal, governance) documented

Evidence Link(s):

12) Audit Readiness & Traceability Checks

- ☐ All required artifacts present for assigned risk tier
- ☐ Dates and versions are current (no expired approvals)
- ☐ Evidence is traceable to source systems (no screenshots only, where better evidence exists)
- ☐ Approvals are signed/attributable (name + date)
- ☐ Open issues/exceptions are clearly listed and linked
- ☐ Next review date recorded
- ☐ Retention location and retention period documented

Notes:

Final Review & Sign-Off

Status:

☐ Complete ☐ Complete with Conditions ☐ Incomplete (Do Not Approve)

Missing Items / Conditions (if any):

Reviewed By (AI Governance)	Name / Signature: _____	Date: _____
Reviewed By (Security)	Name / Signature: _____	Date: _____
Reviewed By (Privacy)	Name / Signature: _____	Date: _____
Reviewed By (Legal/Compliance)	Name / Signature: _____	Date: _____
Business Owner Acknowledgment	Name / Signature: _____	Date: _____